A S S I G N M E N T

A STUDY OF THE EIGHT CISSP DOMAINS: SHORT NOTES AND PERSONAL REFLECTION

Course: Cybersecurity Fundamentals / Ethical Hacking

Instructor: Digital Eselsa

Student: Raphael Ndidi-Uboma

PART 1: SHORT NOTES ON THE EIGHT CISSP DOMAINS

1. Security and Risk Management

This is the foundation of CISSP and the domain closest to GRC. It explains how an organisation governs security, manages risk, and meets its legal and ethical duties. Key concepts include the CIA triad (confidentiality, integrity and availability), policies, standards and procedures, risk assessment, and the four risk treatments: accept, avoid, transfer or mitigate. It also covers compliance, privacy, business continuity planning and professional ethics. In the real world, a company that holds customer data must follow laws such as the Nigeria Data Protection Act 2023 or the GDPR, and must show that it manages risk properly. Security teams do this by keeping risk registers, running risk assessments and training staff on policy. Common frameworks and tools include ISO/IEC 27001, the NIST Risk Management Framework, COBIT, and GRC platforms such as ServiceNow, Archer and OneTrust.

2. Asset Security

Asset Security is about knowing what an organisation owns and protecting it throughout its life. Assets include data, devices, software and people. Key responsibilities are identifying assets, classifying data (for example public, internal, confidential and restricted), assigning data owners and custodians, setting retention periods, and disposing of information safely when it is no longer needed. Privacy protection is also a major part of this domain. In real life, a hospital classifies patient records as highly sensitive, encrypts them, limits who can open them, and shreds old paper files securely. A bank does the same with customer account data. Useful tools and practices include asset inventories and CMDBs, data loss prevention (DLP) software such as Microsoft Purview, encryption, data masking, and secure wiping or physical destruction of old drives.

3. Security Architecture and Engineering

This domain focuses on designing and building systems that are secure from the start rather than adding security later. Key concepts include secure design principles such as least privilege, defence in depth, fail-safe defaults and zero trust. It also covers security models,

cryptography, secure hardware, cloud and virtualisation security, and physical security of buildings and data centres. A real example is an online banking platform: it uses encrypted connections, layered controls, separated networks and a protected data centre so that one failure does not expose everything. Common technologies include encryption standards such as AES and RSA, public key infrastructure (PKI), TLS certificates, hardware security modules (HSMs), trusted platform modules (TPMs), and cloud security architectures on platforms like AWS and Microsoft Azure.

4. Communication and Network Security

This domain deals with protecting data as it moves across networks and protecting the network itself. Key concepts include the OSI and TCP/IP models, secure protocols such as TLS, IPsec and SSH, network segmentation, VLANs, wireless security, and common attacks such as sniffing, spoofing and denial of service. In practice, remote workers connect to the office through a VPN, and companies place payment systems on a separate network from guest Wi-Fi so that a breach in one area does not spread. Examples of tools and practices include firewalls, intrusion detection and prevention systems (Snort and Suricata), Wireshark for traffic analysis, VPN gateways, WPA3 for Wi-Fi, and network access control (NAC) to check devices before they connect. These controls help organisations detect problems early and limit the damage of an attack.

5. Identity and Access Management (IAM)

IAM makes sure the right people have the right access to the right resources at the right time. Key concepts include identification, authentication, authorisation and accountability. It also includes multi-factor authentication (MFA), access control models such as DAC, MAC, RBAC and ABAC, single sign-on (SSO), federation, and the identity lifecycle from joining an organisation to leaving it. Privileged access management is also important because administrator accounts are high-value targets. In real life, a new employee receives access based on their job role, and when they resign their accounts are disabled immediately. This reduces insider risk and supports audits. Common tools and standards include Microsoft Entra ID, Okta, CyberArk, SAML, OAuth, and authenticator apps for MFA. Regular access reviews are also a common practice to remove permissions that are no longer needed.

6. Security Assessment and Testing

This domain is about checking whether security controls actually work. Key concepts include vulnerability assessments, penetration testing, security audits, log reviews, and measuring results with security metrics. Audits can be internal, external or carried out by a third party. Findings are reported to management so that weaknesses can be fixed. In the real world, many organisations run yearly penetration tests and audits to satisfy regulators and customers, for example through SOC 2 or ISO 27001 certification. For GRC professionals this domain is very important because audit evidence proves that the organisation is following its own rules. Common tools and practices include Nessus and OpenVAS for vulnerability scanning, Nmap for network discovery, Burp Suite and Metasploit for testing, and audit checklists and control testing.

7. Security Operations

Security Operations covers the daily work of keeping an organisation safe and responding when something goes wrong. Key responsibilities include monitoring and logging, incident response, digital forensics, patch and configuration management, change management, backup, disaster recovery and business continuity. In practice, a security operations centre (SOC) analyst might notice many failed logins from a foreign country, investigate the alert, block the attacker and document what happened. This domain also links to GRC, because incident reports and recovery plans must be documented and tested. Common tools include SIEM platforms such as Splunk and Microsoft Sentinel, endpoint detection and response (EDR) tools, SOAR automation, ticketing systems, and regular backup and recovery testing. Together, these practices help the organisation recover quickly and learn from every incident.

8. Software Development Security

This domain focuses on building security into software throughout its life, from planning to retirement. Key concepts include the software development life cycle (SDLC), secure coding practices, the OWASP Top 10 web risks, code review, security testing, change control and DevSecOps. It also covers risks from third-party libraries and the software supply chain. A real example is a fintech company that tests its mobile app and fixes weaknesses such as SQL injection before release, which is cheaper and safer than fixing

them after a breach. Common tools and practices include SAST and DAST tools such as SonarQube and OWASP ZAP, dependency scanners such as Snyk, Git with code review, and threat modelling methods such as STRIDE. Developers and security teams work together so that security is checked at every stage instead of only at the end.

PART 2: PERSONAL REFLECTION (CONCLUSION)

The domain I find most interesting is Security and Risk Management, because it is the heart of Governance, Risk and Compliance (GRC), which is the area I am currently training in. Technical tools are important, but every security decision should start with a business question: what are we protecting, what could go wrong, and how much risk is acceptable? This domain answers those questions and connects technology to the goals of the organisation.

I want to specialise in GRC because it combines policy, law, audit and business thinking with cybersecurity. I enjoy structured work such as assessing risks, writing clear policies and checking that controls are followed. I also see strong demand for it in Nigeria and worldwide, as data protection laws and industry rules such as those for banking and fintech keep growing.

Career opportunities include GRC analyst, risk analyst, compliance officer, IT auditor, information security officer, privacy or data protection officer, third-party risk manager, and later Chief Information Security Officer (CISO). Certifications such as ISC2 CC, ISO 27001 Lead Implementer or Auditor, CISA, CRISC and CISSP can support this path.

To succeed I need to develop several skills. First, I must understand frameworks such as ISO 27001, NIST CSF and NIST SP 800-53, and relevant laws. Second, I need strong writing and communication skills, since I will explain risk to managers who are not technical. Third, I need analytical skills for risk assessment and audit evidence. I also need basic technical knowledge of networks, cloud and access control so that I can understand the controls I review, along with integrity, attention to detail and the habit of continuous learning.

Bonus: About ISC2

ISC2 (the International Information System Security Certification Consortium) is a global

non-profit membership organisation founded in 1989. It is best known for creating and maintaining the CISSP certification, along with other credentials such as SSCP and Certified in Cybersecurity (CC). ISC2 publishes the Common Body of Knowledge that defines the CISSP domains, sets the Code of Ethics that members must follow, and requires continuing professional education so that certified people keep their skills current. In this way, ISC2 helps set a trusted global standard for cybersecurity professionals and supports the growth of the workforce.